

-

File No.: PS/00477/2022

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: Mr. A.A.A. (hereinafter, the claimant) filed a complaint with the Spanish Agency for Data Protection on May 10, 2022. The complaint is directed against the CITY COUNCIL OF SANTIAGO DE COMPOSTELA with NIF P1507900G (hereinafter, the respondent). The reasons on which the complaint is based are as follows:

That on May 10, 2022, he received an uncertified letter without an envelope sent by the respondent. The letter was folded in such a way that all persons who handled it could see the personal data of the claimant that appeared on the back of the letter, specifically his ID number, name and surname, address, car registration, make and model of his car, as well as the fact that the letter is a notice for speeding.

He attaches a copy of the open letter as well as the folded letter as received. In this latter case, the following can be seen:

- On the back: Date and time of the notice; type of vehicle; registration, make and model of the vehicle; name, surname, address, and ID number of the claimant; reported facts and the amount of the fine.
- On the front: Logo of the Concello de Santiago, the address of the Fine Management Office, barcode, that it is a "request for identification of the driver" and the name, surname, and address of the claimant as the recipient of the letter.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter LOPDGDD), the complaint was forwarded to the respondent, so that they could analyze it and inform this Agency within one month of the actions taken to comply with the requirements set forth in the data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was received on June 10, 2022, as stated in the acknowledgment of receipt in the file.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/19

As no response was received to this forwarding letter, it was reiterated, which was notified in accordance with the rules established in the LPACAP, on August 8, 2022, as stated in the acknowledgment of receipt in the file.

THIRD: On August 10, 2022, in accordance with Article 65 of the LOPDGDD, the complaint filed by the claimant was admitted for processing.

FOURTH: On September 19, 2022, a letter from the respondent was received by this Agency in response to the forwarding of the complaint, in which it states:

"In sanctioning procedures in traffic matters, the first communication made to the interested party, in cases of minor and serious infractions, without point deductions, is carried out by sending the alleged offender an ordinary letter with 'Postage Paid', through the postal operator Correos.

This letter only contains the minimum adequate and pertinent data for the processing of sanctioning files in traffic matters.

These data that appear on the visible part of the ordinary letter or in the notifications sent are always the necessary and essential ones for these notifications to be properly carried out: name, surname, address of the alleged offender, and reference to the administrative file.

In no case does the document contain the registration number, nor the official identification document, nor the infraction committed. Consequently, the data collected are those necessary to properly carry

out the delivery and receipt by the Correos Service to the recipient of the notification.

The format of the ordinary letter is properly formatted, folded, and creased so that only the following data are visible:

- Logo of Concello de Santiago de Compostela.
- Address of the Fine Management Office.
- Key: ND
- Barcode (string of numbers)
- Surname and name of the recipient.
- Address of the recipient.

(...)

Both ordinary letters and notifications are properly folded and sealed, so that the content can be accessed.

Therefore, if any person who is not the recipient of the notification accesses its content, they would be violating the duty of confidentiality. Since the guarantee of confidentiality is preserved by the very format of the document, which cannot be accessed unless the letter or envelope is opened."

He attaches a copy of the model for sending such a document, in which it can be seen:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/19

- On the reverse: A box indicating that the postman should mark with an "X" the reason for the return (unknown, refused, absent, incorrect address, other reasons).
- On the front: Logo of the Concello de Santiago, the address of the Fines Management Office, ND key, barcode, and a box within which "recipient" is indicated.

FIFTH: On September 23, 2022, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the respondent, in accordance with the provisions of Articles 63 and 64 of the LPACAP, for the alleged infringement of Article 32 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), classified under Article 83.4 of the GDPR.

SIXTH: Once the aforementioned initiation agreement was notified in accordance with the rules established in the LPACAP, the respondent submitted a written statement of allegations in which, in summary, it stated that "it does not consider that Article 32 of the GDPR, classified under Article 83.4 of that legal norm, has been breached, since the City Council has adopted the technical and organizational measures that it deems appropriate to guarantee an adequate level of security in relation to the risk of processing, in the legally established terms, and therefore, it is considered that no sanction should be imposed."

It indicates that the model document it uses for the notification of a driver identification request "consists of four parts that are sent to the recipient properly folded and with their edges glued, in such a way that both the front and the back correspond to what would be the envelope and receipt notice, parts that only contain the necessary data for their delivery and receipt through the postal service:

DENUNCIATION ENVELOPE (White Color)

City Council Logo - Department sending the notification

Recipient: Name and surname

Recipient's address

Postage Paid

Driver Identification Request

(...)

The personal data forms part of the content of the notification, place of infringement, day and time of the infringement, name and surname of the owner of the reported vehicle, license plate, make and model of the reported vehicle, etc., only form part of the "non-visible" document, that is, that part of the notification is not accessible, in such a way that, to access that content, it is necessary to unfold the

envelope or tear its ends, which, as already stated, are perfectly glued."

It points out that "The data that appears on the visible part of both ordinary letters and notifications are the minimum necessary and essential for the notification to be carried out: name, surname, address, and reference of the administrative file, and no other data is recorded that could reveal to third parties a disadvantageous condition of the recipient, and, in this sense, this administration operates in every case."

(...)

"In no case can access be gained to the content of data such as the vehicle's license plate, ID number, reported facts, or the amount of the sanction if the letter is not torn at the ends or peeled off."

It states that "the interested party in their complaint confirms that the letter had been opened and therefore, any person could access its content, this circumstance can occur both in the format of the shipment sent by the city council (folded and glued letter) and in that of a certified envelope; since certified labels tend to peel off easily and anyone can open the envelope and access its content."

Subsequently noting that "it is unknown what may have happened in this specific case, for the complainant to have received the letter opened and with their identification data visible."

It expresses that "There is no doubt that, in this specific case, an incident may have occurred that has affected the security of this notification, but as previously stated, this is the first time that this administration has been reported for a breach of this type and it is considered that the security measures are adequate and proportionate to the risk."

It considers that this exceptionality "would need to be analyzed in more detail to determine what, in this specific case, has led to the letter being received by the recipient opened."

SEVENTH: On February 1, 2023, the instructor agreed to open a phase for the practice of evidence consisting of:

- 1.- Incorporating into the file, for evidentiary purposes, the complaint that gave rise to the sanctioning procedure and its attached documentation; the documents obtained and generated during the admission phase of the complaint and the allegations to the initiation agreement of PS/00477/2022 presented by the respondent.
- 2.- Requesting the respondent for the pink receipt related to the notification of the driver identification request of Exp. XXXX/XXXXX.
- 3.- Requesting the complainant to indicate the means by which they received on May 10, 2022, the document from the respondent that has given rise to the present sanctioning procedure (personally by a postal official, in the mailbox, at a post office, delivered by a third party).

The request to the respondent and the request for information to the complainant were carried out in accordance with the rules established in the LPACAP.

No response has been received to either the aforementioned request or the cited request for information.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/19

On February 21, 2023, the instructor of the procedure agreed to carry out new evidence gathering before the claimed party consisting of a request for:

- Sending the pink receipt notice related to the notification of the request for driver identification of Exp. XXXX/XXXXX.

- Indication regarding whether the requests for driver identification that are notified by post are sent in sealed envelopes or are folded and glued documents. In the latter case:

a) Sending a copy of a model document.

b) Indication of what content would be visible once the pink notice is peeled off.

On February 28, 2023, a response was received from the claimed party to the second evidence

request, in which they inform the following:

"The requests for driver identification that are notified by post are sent in properly folded and glued documents, on a type of paper that we call four-fold (one of which is pink). The dimensions of the paper are: height 41.6 cm, width 21.4 cm, with each fold being 10.4 cm, folded into four parts. Once the pink notice is peeled off, no data related to the request would be visible, as can be verified in the current model document and in the photographs that will accompany this report as an example of folding."

Attached to the report is the following documentation:

- Pink receipt notice related to the notification of the request for driver identification of file XXXX/XXXXX, in which it is observed that the notification was delivered to the postal address of the claimant, by a postal worker, on May 10, 2022, and collected by Mr. B.B.B., grandfather of the claiming party.
- Current model document of the open request.
- Three photographs of the current model of the request:
 - a) One related to the "example of folding," in which it can be seen that the driver identification request document is folded into four parts, among which the front side of the document is distinguished.
 - b) Another related to the front of the request, in which it can be seen: The logo of the Concello de Santiago, the address of the Fine Management Office, a barcode, that it is a "request for driver identification" and a box to enter the claimant's data as the recipient of the letter.
 - c) And another related to the back of the request, which corresponds to the pink receipt related to the notification of the identification request.

OCTAVO

On March 30, 2023, a resolution proposal was made, proposing that the Director of the Spanish Agency for Data Protection sanction AYUNTAMIENTO DE SANTIAGO DE COMPOSTELA, with NIF P1507900G, for an infringement of Article 5.1.f) of the GDPR, classified under Article 83.5.a) of the GDPR, and for an infringement of Article 32 of the GDPR, classified under Article 83.4.a) of the GDPR, with a warning sanction.

NINTH: Once the resolution proposal was notified in accordance with the rules established in the LPACAP, the claimed party submitted a written statement of allegations on April 17, 2023, in which, in summary, they stated that:

1.- "This Administration accepts the proposed sanction; however, it reiterates that the means used to carry out the notification was appropriate, once weighing the state of the art, the costs of application, and the nature, scope, context, and purposes of the processing; as well as the variable probability and severity risks for the rights and freedoms of individuals, since the only way to access the personal identifying data of the interested party or the procedure was once the pink paper of the certificate was extracted, a circumstance that, under normal conditions, the postal worker performs once they deliver the document to the interested party, for them to sign the receipt or, by any person, upon prior identification, who is at the interested party's address.

Consequently, we understand that there has been no lack of minimum diligence on the part of the data controller by allowing the exhibition of the data to third parties unrelated to the interested party.

The postal worker who delivers the notification, only at this moment, once the pink paper is peeled off and handed over for signature, could access the personal data of the interested party; however, these persons are bound by the confidentiality commitment, so they cannot disclose the information they might access through the delivery of shipments via the public operator.

The rest of the people who could have access to this information are those residing at the interested party's address, upon accreditation of this fact, so it can be presumed that these persons will not misuse it.

Moreover, it is important to consider that if the claimant did not want the resident person or someone who is temporarily at the address to have access to their personal data, they would not allow them to collect the shipment, since it is not mandatory for the notification to be received by a person to whom it is not addressed, not even by the addressee themselves, Article 41 of Law 39/2015, of October 1."

2.- On the other hand, it refers to the document that it has sent "prior to the initiation of this file" "in the format described in the resolution proposal, point II of the Legal Grounds," which does not expose

data.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
7/19

of the recipient's identification of the document once the receipt notice justifying the notification practice is removed.

From the actions taken in this procedure and the documentation in the file, the following has been established:

PROVEN FACTS

FIRST: It is established that on May 10, 2022, the party being claimed notified, through a postal official, a request for driver identification to the claiming party, a notification that was collected, at the postal address of the claiming party, by their grandfather.

On the front of the request sent to the claiming party, when it is folded and closed, the following can be seen: Logo of the Concello de Santiago, the address of the Fines Management Office, barcode, that it is a "request for driver identification" and the name, surname, and address of the claimant as the recipient of the letter.

On the back of the request sent to the claiming party, when it is folded and closed, and once the pink receipt notice related to the notification has been removed, the following can be seen: Date and time of the complaint; type of vehicle; license plate, make, and model of the vehicle; name, surname, address, and D.N.I. of the claimant; reported facts and the amount of the fine.

Once opened and unfolded, the request sent to the claiming party is observed to be a document folded into three parts.

SECOND: The claiming party has filed a complaint with the AEPD alleging that on that same day they had "received an uncertified letter without an envelope" sent by the party being claimed. They indicate that the letter "was folded in such a way that all the people it passed through could see my personal data, which appears on the back of it. Data such as: D.N.I., NAME AND SURNAME, MAKE AND MODEL OF THE CAR... AS WELL AS THEY COULD SEE THAT THE LETTER IS A COMPLAINT FOR SPEEDING."

They attach a copy of the open letter as well as the letter folded as they received it.

THIRD: It is established that, since the party being claimed responded to the second request for evidence collected in this procedure, the request for driver identification sent by them has the following characteristics:

- It is a document properly folded into four parts and glued.
- On the front of the request, when it is folded and closed, the following can be seen: Logo of the Concello de Santiago, the address of the Fines Management Office, barcode, that it is a "request for driver identification" and the name, surname, and address of the claimant as the recipient of the letter.
- The back of the request, when it is folded and closed, corresponds to the pink receipt related to the notification of the request for identification.

LEGAL GROUNDS

I

In accordance with the powers granted to each supervisory authority by Article 58.2 of the GDPR and as established in Articles 47, 48.1, 64.2, and 68.1 of the LOPDGDD, the Director of the Spanish Data Protection Agency is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Data Protection Agency shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

The party being claimed states in their written allegations to the initiation agreement that "it is not considered that Article 32 of the GDPR, classified in Article 83.4 of that legal norm, has been violated, since the City Council has adopted the technical and organizational measures that it deems

appropriate to guarantee an adequate level of security to the risk of processing, in the legally established terms and therefore, it is considered that no sanction should be imposed."

They also indicate that the model document they use for the notification of a request for driver identification "consists of four parts that are sent to the recipient properly folded and with glued edges, in such a way that both the front and the back correspond to what would be the envelope and receipt notice, parts that only contain necessary data for their delivery and receipt through the postal service:

COMPLAINT ENVELOPE (White Color)

Logo City Council - Department sending the notification

Recipient: Name and surname

Recipient's address

Postage Paid

Request for Driver Identification

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/19

Personal data is part of the content of the notification, including the place of the infraction, date and time of the infraction, name and surname of the owner of the reported vehicle, license plate, make and model of the reported vehicle, etc. This information is only part of the "invisible" document, meaning that this part of the notification is not accessible. Therefore, to access this content, it is necessary to unfold the envelope or break its ends, which, as previously stated, are perfectly sealed.

However, the model of the driver identification request sent by the responding party during the evidentiary period differs substantially from that provided by the claiming party in the complaint submitted to this Agency. The present sanctioning procedure must adhere to the latter.

In this case, as indicated in the first of the proven facts, the notification of the driver identification request was carried out by a postal official at the residence of the claiming party, and this notification was received by the grandfather of the claiming party, as recorded in the acknowledgment of receipt of the notification.

It was when this acknowledgment of receipt was removed that the date and time of the complaint; type of vehicle; license plate, make and model of the vehicle; name, surname, address, and ID number of the claimant; reported facts; and the amount of the fine were exposed on the reverse side of the still closed and folded notification.

Article 42.2 of the LPACAP states that "When the notification is made at the domicile of the interested party, if the interested party is not present at the time the notification is delivered, any person over fourteen years of age who is present at the domicile and can prove their identity may take charge of it. (...)"

However, this provision does not mean that personal data can be exposed once the corresponding acknowledgment of receipt justifying the notification has been removed from the document, as has occurred in this case.

Notwithstanding the above, the responding party considers in its written allegations to the proposed resolution that "the means used to carry out the notification was appropriate," adding that:

"The postal official who delivers the notification, only at this moment, once the pink paper is peeled off and handed over for signature, could access the personal data of the interested party; however, these individuals are bound by the confidentiality commitment, so they cannot disclose the information they might access through the delivery of shipments via the public operator.

The other individuals who could have access to this information are those residing at the interested party's domicile, upon verification of this fact, so it can be presumed that these individuals will not misuse it."

In this regard, it is necessary to bring to attention, as already indicated in the proposed resolution, Article 13.h) of the LPACAP, "Rights of individuals in their relations with Public Administrations," which establishes the following:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
10/19

"Those who, in accordance with Article 3, have the capacity to act before the Public Administrations, are entitled to the following rights:

h) The protection of personal data, and in particular the security and confidentiality of the data contained in the files, systems, and applications of the Public Administrations."

And we cannot forget that individuals have the power of disposition over their personal data, as well as over its dissemination, resulting, without a doubt, in the person whose personal data is disseminated in violation of the legal order being deserving of protection.

In this regard, the Constitutional Court ruling STC 292/2000, of November 30, states that "the content of the fundamental right to data protection consists of a power of disposition and control over personal data that enables the individual to decide which of those data to provide to a third party, whether the State or a private individual, or which data this third party may collect, and that also allows the individual to know who possesses that personal data and for what purpose, being able to oppose such possession or use. These powers of disposition and control over personal data, which constitute part of the content of the fundamental right to data protection, are legally specified in the authority to consent to the collection, obtaining, and access to personal data, its subsequent storage and processing, as well as its possible use or uses, by a third party, whether the State or a private individual. And this right to consent to the knowledge and processing, whether computerized or not, of personal data requires as indispensable complements, on the one hand, the authority to know at all times who disposes of that personal data and what use they are subjecting it to, and, on the other hand, the power to oppose such possession and uses."

The confidentiality commitment to which the postal staff is subject, as well as the use that a third party, who is at the recipient's address, makes of that data, is irrelevant, because the truth is that with the exposure of such data upon the withdrawal of the pink receipt notice related to the notification, the claiming party has lost their power of disposition and control to decide whether to provide that data to a third party or not.

On the other hand, the responding party indicates in their written allegations to the proposed resolution that "it is important to note that if the claimant did not want the person residing or temporarily present at the address to have access to their personal data, they would not allow them to collect the delivery, since the receipt of the notification by the person to whom it is not addressed is not mandatory, not even by the addressee themselves, as per Article 41 of Law 39/2015, of October 1."

While it is true that the receipt of the notification is not mandatory, this cannot mean, as has already been indicated, that the personal data of the recipient may remain exposed once the pink receipt notice has been withdrawn.

Furthermore, it should be noted that such an assertion is unfounded since, in the present case, we are talking about a notification of driver identification,

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
11/19

wherefore the claiming party could not have been expecting such notification and, therefore, could not have made it impossible to collect the shipment.

III

The responding party concludes its arguments regarding the initiation agreement by stating that "It is not in doubt that, in this specific case, an incident may have occurred that has affected the security of this notification, but as previously stated, this is the first time that this administration has been reported for a breach of this type, and it is considered that the security measures are adequate and proportionate to the risk."

Recital 74 of the GDPR establishes that:

“The responsibility of the data controller must be established for any processing of personal data carried out by themselves or on their behalf. In particular, the controller must be obliged to apply appropriate and effective measures and must be able to demonstrate compliance of the processing activities with this Regulation, including the effectiveness of the measures. Such measures must take into account the nature, scope, context, and purposes of the processing, as well as the risk to the rights and freedoms of natural persons.”

Translating this recital to the specific case being examined, it can be concluded that, at the time of the shipment, the responding party did not have reasonable security measures in place based on the estimated potential risks, since the fact that personal data related to the traffic violation is left on the external part of the sent document makes the data accessible, not only to the notifying agent who collects the acknowledgment of receipt but also to any other person who may physically handle the letter, as has occurred in the present case, where the notification was delivered to a person other than the recipient who was at their home, as allowed by the aforementioned Article 42.2 of the LPACAP. It is true that the responding party states that currently the notification of the request for driver identification does not expose personal data on the exterior of the letter once the acknowledgment of receipt justifying the notification practice is removed.

However, as previously indicated, the notification that is the subject of this sanctioning procedure is the one received by the claiming party, making it irrelevant how the notification of the request for driver identification is currently carried out or that it is the first time the responding party has been reported for this issue.

For the reasons stated, the allegations made by the responding party regarding both the initiation agreement and the proposed resolution are dismissed.

IV

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/19

In the present case, in accordance with the provisions of Article 4.1 of the GDPR, there is evidence of the processing of personal data, given that the responding party, in its relations with citizens, carries out various processing activities, including the handling of administrative sanctioning procedures in the area of Traffic and the notification of documents, which involves the organization, consultation, use, and communication of, among others, the following personal data of individuals: name, surname, address, and vehicle registration number, understanding personal data as: “any information relating to an identified or identifiable natural person.”

The responding party carries out this activity in its capacity as the data controller, as it is the one who determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR, which defines the “data controller” or “controller” as: “the natural or legal person, public authority, agency, or other body that, alone or jointly with others, determines the purposes and means of the processing; where the law of the Union or of the Member States determines the purposes and means of the processing, the controller or the specific criteria for its appointment may be laid down by the law of the Union or of the Member States.”

An identifiable natural person is considered to be one whose identity can be determined, directly or indirectly, in particular by means of an identifier, such as a name, identification number, location data, an online identifier, or one or several elements specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that person.

Furthermore, processing must be understood as “any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination, or any other form of enabling access, alignment, combination, restriction, erasure, or destruction.”

V

Article 5.1.f) of the GDPR, "Principles relating to processing," establishes:

"1. Personal data shall be:

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures ('integrity and confidentiality')."

From the documentation in the file, there is clear evidence that the responding party has violated Article 5.1.f) of the GDPR, as the notification of the requirement for driver identification addressed to the claimant was collected, in accordance with Article 42.2 of the LPACAP, by the grandfather of the claimant; a person who had access to it, once the acknowledgment of receipt justifying the practice of such notification was removed, and with the document still sealed.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/19

and folded, a series of personal data of the claimant was exposed, specifically the date and time of the complaint; type of vehicle; license plate, make and model of the vehicle; name, surname, address, and ID number of the claimant; reported facts and the amount of the fine.

The aforementioned Article 42.2 of the LPACAP states that "When the notification is made at the domicile of the interested party, if the interested party is not present at the time the notification is delivered, any person over fourteen years of age who is at the domicile and can provide their identity may take charge of it. (...)".

In the same vein, the Regulation governing the provision of postal services indicates in section 2 of its Article 41, "General provisions on the delivery of notifications," that "When the notification is made at the domicile of the interested party and the interested party is not present at the time of delivering said notification, any person who is at the domicile and can provide their identity may take charge of it."

However, such provisions do not encompass the possibility that personal data may be exposed once the corresponding acknowledgment of receipt justifying the notification has been removed from the document. Therefore, the exposure of personal data that has occurred in the present case constitutes a violation of Article 5.1.f) of the GDPR.

VI

Prior to this, it should be noted that, regarding envelopes sent to notify or inform, with the addresses of the recipients and additional information on their side, for example containing "debt collection," or similar, several rulings from the National Court, Administrative Litigation Chamber, first section, although in the private sphere, not in the notification of an administrative act, have confirmed resolutions from the AEPD imposing sanctions for violating the principles of security in data processing. To cite two, the ruling SAN of April 15, 2014, appeal 143/2013 and the ruling SAN of July 10, 2014, appeal 212/2013. In both, it is indicated that the supports and documents violate security measures in processing when, in the transfer of supports and documents containing personal data, they do not adopt measures aimed at preventing unauthorized access to the information during its transfer.

Article 32 of the GDPR, "Security of processing," establishes:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying probabilities and severity of risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

a) the pseudonymization and encryption of personal data;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/19

- b) the ability to ensure the confidentiality, integrity, availability, and permanent resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process of regular verification, evaluation, and assessment of the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the adequacy of the level of security, particular consideration shall be given to the risks presented by the data processing, especially as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data following the instructions of the controller, unless required to do so by Union or Member State law.

The responding party has attached a model of how the notifications sent by the Fine Management Office of the Santiago City Council are structured, which would include the minimum necessary data for processing sanctioning files related to traffic. However, the fact is that such notification differs from the document provided by the claiming party, in which personal data of the individual is clearly exposed on the exterior of the letter, data that should not have been disclosed, specifically their ID number; type of vehicle registered in their name; license plate, make, and model of the vehicle; date and time of the complaint filed against them; the reported facts and the amount of the fine; and that it is a "request for identification of the driver," without any explanation provided by the responding party regarding what may have occurred in this specific case.

The documentation in the file provides clear indications that the responding party has violated Article 32 of the GDPR, as it has not adopted appropriate technical and organizational measures to ensure a level of security appropriate to the risk, by allowing the display of personal data of the recipient of the notification of a sanctioning procedure related to traffic, which constitutes a lack of minimum diligence by the controller, regardless of the personal data breach that occurred. The responding party, as the data controller, must implement the means and measures to ensure that all its personnel are aware of and comply with the responsibilities in handling personal data, with access to the content of the document limited to assigned personnel, both during its processing and thereafter.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/19

In this case, because the data regarding the infringement committed by the citizen is located on the external part of the letter, when the notifying agent removed the delivery receipt attached to it, the details of the sanctioning procedure that were subject to notification were exposed to anyone: name, surname, address, and ID number of the now claimant; type of vehicle registered in their name; license plate, make, and model of the vehicle; date and time of the complaint filed against them; the reported facts and the amount of the fine; and that it is a "request for identification of the driver."

It should be noted that the GDPR in the cited Article 32 does not establish a list of security measures applicable according to the data being processed, but rather states that the data controller and the processor shall implement technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the risks of likelihood and severity for the rights and freedoms of the data subjects.

Furthermore, the security measures must be adequate and proportionate to the identified risk,

indicating that the determination of technical and organizational measures should be made considering: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, verification process (which is not an audit), evaluation, and assessment of the effectiveness of the measures.

In any case, when evaluating the adequacy of the level of security, particular attention shall be paid to the risks presented by the data processing, as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial harm.

In this same vein, Recital 83 of the GDPR states that "(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or processor must assess the inherent risks of the processing and implement measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation concerning the risks and the nature of the personal data to be protected. When assessing the risk in relation to the security of the data, the risks arising from the processing of personal data must be considered, such as the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, particularly susceptible to causing physical, material, or immaterial harm."

Recital 75 of the GDPR lists a series of factors or assumptions associated with risks to the guarantees of the rights and freedoms of the data subjects:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/19

"The risks to the rights and freedoms of individuals, varying in severity and likelihood, may arise from the processing of data that could cause physical, material, or immaterial harm, particularly in cases where the processing may lead to issues of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm; in cases where individuals are deprived of their rights and freedoms or prevented from exercising control over their personal data; in cases where the processed personal data reveal ethnic or racial origin, political opinions, religion or philosophical beliefs, union membership, and the processing of genetic data, health-related data, or data concerning sexual life, or criminal convictions and related security measures; in cases where personal aspects are evaluated, particularly the analysis or prediction of aspects related to work performance, economic situation, health, personal preferences or interests, reliability or behavior, situation or movements, in order to create or use personal profiles; in cases where personal data of vulnerable individuals, particularly children, are processed; or in cases where the processing involves a large amount of personal data and affects a large number of individuals."

The responsibility of the defendant is determined by the security breach evidenced in the complaint and the documentation provided, as it is responsible for making decisions aimed at effectively implementing appropriate technical and organizational measures to ensure a level of security appropriate to the risk, to ensure that the data is not visible to anyone receiving the shipment. In the absence of a physical element that prevents or reveals unauthorized access to the content of the postal communication, personal data remains unprotected.

VII

In accordance with the available evidence, it is considered that the facts presented violate the provisions of Articles 5.1(f) and 32 of the GDPR, which constitutes the commission of the infringements classified in Article 83, paragraphs 4(a) and 5(a) of the GDPR, which state the following: "4. Infringements of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual

global turnover of the preceding financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43;
(...)

5. Infringements of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 4% of the total annual global turnover of the preceding financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9;"

In this regard, the LOPDGDD, in its Article 71 "Infringements," establishes that "Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

On the other hand, Article 72 of the LOPDGDD indicates, for the purposes of the limitation period: "Article 72. Very serious infringements.

1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and shall be subject to a limitation period of three years, which involve a substantial violation of the articles mentioned therein, and in particular, the following:

a) The processing of personal data violating the principles and guarantees established in Article 5 of Regulation (EU) 2016/679."

While Article 73 of the LOPDGDD indicates, for the purposes of the limitation period:

"Article 73. Serious infringements.

In accordance with what is established in Article 83.4 of Regulation (EU) 2016/679, the following infringements are considered serious and shall be subject to a limitation period of two years, which involve a substantial violation of the articles mentioned therein, and in particular, the following:

(...)

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security appropriate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679."

VIII

Article 83 "General conditions for the imposition of administrative fines" of the GDPR in its paragraph 7 establishes:

"Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines may be imposed on authorities and public bodies established in that Member State."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/19

Furthermore, Article 77 "Applicable regime for certain categories of data controllers or processors" of the LOPDGDD provides as follows:

"1. The regime established in this article shall apply to the processing for which the following are responsible or act as processors:

(...)

c) The General Administration of the State, the administrations of the autonomous communities, and the entities that comprise the Local Administration.

(...)

2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution sanctioning them with a warning. The resolution shall also establish the measures that should be adopted to cease the conduct or correct the effects of the infringement that has been committed.

The resolution shall be notified to the data controller or processor, to the body to which they hierarchically depend, if applicable, and to the affected parties who qualify as interested parties, if applicable.

3. Without prejudice to the provisions of the previous paragraph, the data protection authority shall also propose the initiation of disciplinary proceedings when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied shall be those established in the legislation on disciplinary or sanctioning regimes that are applicable.

Furthermore, when the infringements are attributable to authorities and executives, and it is proven that there are technical reports or recommendations for processing that have not been duly addressed, the resolution imposing the sanction shall include a reprimand naming the responsible position and shall order publication in the corresponding Official State or autonomous Gazette.

4. The resolutions relating to the measures and actions referred to in the previous paragraphs shall be communicated to the data protection authority.

5. The actions carried out and the resolutions issued under this article shall be communicated to the Ombudsman or, where applicable, to the analogous institutions of the autonomous communities.”

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established,

the Director of the Spanish Agency for Data Protection RESOLVES:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/19

FIRST: TO IMPOSE on the CITY COUNCIL OF SANTIAGO DE COMPOSTELA, with NIF P1507900G, a warning sanction for the infringement of the following articles:

- Article 5.1.f) of the GDPR, classified in Article 83.5.a) of the GDPR.

- Article 32 of the GDPR, classified in Article 83.4.a) of the GDPR.

SECOND: TO NOTIFY this resolution to the CITY COUNCIL OF SANTIAGO DE COMPOSTELA.

THIRD: TO COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of Article 77.5 of the LOPDGDD.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file an appeal for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be suspended provisionally if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of Law 39/2015, of October 1. They must also provide the Agency with documentation evidencing the effective filing of the contentious-administrative appeal. If the Agency does not become aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

938-181022

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid
sedeagpd.gob.es